NIST CSF 2.0 Gap Assessment

NIST CSF v2.0 — Journey

NIST Cybersecurity Framework 2.0 with mapped reference controls for the organisational journey preset

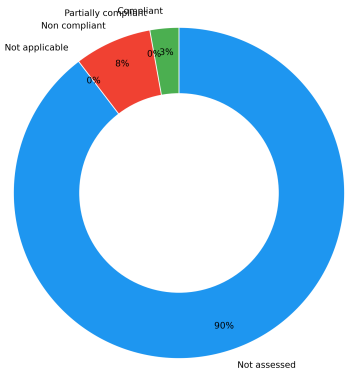
Reference	-
Date	14/10/2026
Implementation groups	All
Contributors	,

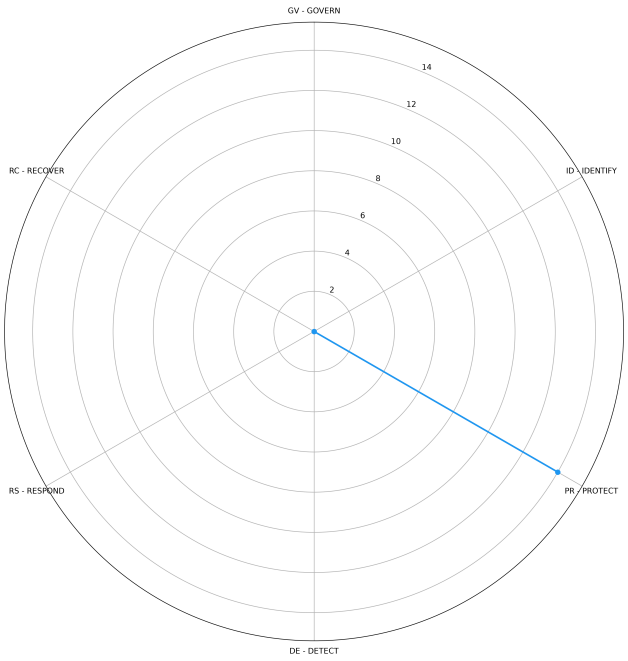
Generated at 2026-10-14 18:25:14 UTC
Document ID eba667fa-1fed-4a59-9cf9-0bd20827b77c

Executive summary

Compliant	Partially compliant	Non compliant	Not applicable	Not assessed
3	0	8	0	95

Compliant on **2.8%** of 106 assessed requirements. 0 applied controls are linked to this audit.





Drifts per domain

Domain	Findings
GV - GOVERN	31
ID - IDENTIFY	21
PR - PROTECT	19
DE - DETECT	11
RS - RESPOND	13
RC - RECOVER	8

Detailed results

106 assessable requirements.

GV.OC-01 — - Not assessed

Progress: To do

The organizational mission is understood and informs cybersecurity risk management.

GV.OC-02 — - Not assessed

Progress: To do

Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered.

GV.OC-03 — - Not assessed

Progress: To do

Legal, regulatory, and contractual requirements regarding cybersecurity are understood and managed.

GV.OC-04 — - Not assessed

Progress: To do

Critical objectives, capabilities, and services that stakeholders depend on or expect from the organization are understood and communicated.

GV.OC-05 — - Not assessed

Progress: To do

Outcomes, capabilities, and services that the organization depends on are understood and communicated.

GV.RM-01 — - Not assessed

Progress: To do

Risk management objectives are established and agreed to by organizational stakeholders.

GV.RM-02 — - Not assessed

Progress: To do

Risk appetite and risk tolerance statements are established, communicated, and maintained.

GV.RM-03 — - Not assessed

Progress: To do

Cybersecurity risk management activities and outcomes are included in enterprise risk management processes.

GV.RM-04 — - Not assessed

Progress: To do

Strategic direction that describes appropriate risk response options is established and communicated.

GV.RM-05 — - Not assessed

Progress: To do

Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties.

GV.RM-06 — - Not assessed

Progress: To do

A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated.

GV.RM-07 — - Not assessed

Progress: To do

Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions.

GV.RR-01 — - Not assessed

Progress: To do

Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving.

GV.RR-02 — - Not assessed

Progress: To do

Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced.

GV.RR-03 — - Not assessed

Progress: To do

Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies.

GV.RR-04 — - Not assessed

Progress: To do

Cybersecurity is included in human resources practices.

GV.PO-01 — - Not assessed

Progress: To do

Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced.

GV.PO-02 — - Not assessed

Progress: To do

Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission.

GV.OV-01 — - Not assessed

Progress: To do

Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction.

GV.OV-02 — - Not assessed

Progress: To do

The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks.

GV.OV-03 — - Not assessed

Progress: To do

Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed.

GV.SC-01 — - Not assessed

Progress: To do

A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders.

GV.SC-02 — - Not assessed

Progress: To do

Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally.

GV.SC-03 — - Not assessed

Progress: To do

Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes.

GV.SC-04 — - Not assessed

Progress: To do

Suppliers are known and prioritized by criticality.

GV.SC-05 — - Not assessed

Progress: To do

Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties.

GV.SC-06 — - Not assessed

Progress: To do

Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships.

GV.SC-07 — - Not assessed

Progress: To do

The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship.

GV.SC-08 — - Not assessed

Progress: To do

Relevant suppliers and other third parties are included in incident planning, response, and recovery activities.

GV.SC-09 — - Not assessed

Progress: To do

Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle.

GV.SC-10 — - Not assessed

Progress: To do

Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement.

ID.AM-01 — - Not assessed

Progress: To do

Inventories of hardware managed by the organization are maintained.

ID.AM-02 — - Not assessed

Progress: To do

Inventories of software, services, and systems managed by the organization are maintained.

ID.AM-03 — - Not assessed

Progress: To do

Representations of the organization's authorized network communication and internal and external network data flows are maintained.

ID.AM-04 — - Not assessed

Progress: To do

Inventories of services provided by suppliers are maintained.

ID.AM-05 — - Not assessed

Progress: To do

Assets are prioritized based on classification, criticality, resources, and impact on the mission.

ID.AM-07 — - Not assessed

Progress: To do

Inventories of data and corresponding metadata for designated data types are maintained.

ID.AM-08 — - Not assessed

Progress: To do

Systems, hardware, software, services, and data are managed throughout their life cycles.

ID.RA-01 — - Not assessed

Progress: To do

Vulnerabilities in assets are identified, validated, and recorded.

ID.RA-02 — - Not assessed

Progress: To do

Cyber threat intelligence is received from information sharing forums and sources.

ID.RA-03 — - Not assessed

Progress: To do

Internal and external threats to the organization are identified and recorded.

ID.RA-04 — - Not assessed

Progress: To do

Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded.

ID.RA-05 — - Not assessed

Progress: To do

Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization.

ID.RA-06 — - Not assessed

Progress: To do

Risk responses are chosen, prioritized, planned, tracked, and communicated.

ID.RA-07 — - Not assessed

Progress: To do

Changes and exceptions are managed, assessed for risk impact, recorded, and tracked.

ID.RA-08 — - Not assessed

Progress: To do

Processes for receiving, analyzing, and responding to vulnerability disclosures are established.

ID.RA-09 — - Not assessed

Progress: To do

The authenticity and integrity of hardware and software are assessed prior to acquisition and use.

ID.RA-10 — - Not assessed

Progress: To do

Critical suppliers are assessed prior to acquisition.

ID.IM-01 — - Not assessed

Progress: To do

Improvements are identified from evaluations.

ID.IM-02 — - Not assessed

Progress: To do

Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties.

ID.IM-03 — - Not assessed

Progress: To do

Improvements are identified from execution of operational processes, procedures, and activities.

ID.IM-04 — - Non compliant

Progress: Done

Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved.

"Observation": Assessment shows that there is no disaster recovery plan.

PR.AA-01 — - Non compliant

Progress: Done **Result detail:** Major nonconformity

Identities and credentials for authorized users, services, and hardware are managed by the organization.

PR.AA-02 — - Not assessed

Progress: To do

Identities are proofed and bound to credentials based on the context of interactions.

PR.AA-03 — - Non compliant

Progress: Done **Result detail:** Minor nonconformity

Users, services, and hardware are authenticated.

PR.AA-04 — - Not assessed

Progress: To do

Identity assertions are protected, conveyed, and verified.

PR.AA-05 — - Non compliant

Progress: Done **Result detail:** Major nonconformity

Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties.

PR.AA-06 — - Compliant

Progress: Done **Result detail:** Good practice

Physical access to assets is managed, monitored, and enforced commensurate with risk.

PR.AT-01 — - Not assessed

Progress: To do

Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind.

PR.AT-02 — - Not assessed

Progress: To do

Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind.

PR.DS-01 — - Non compliant

Progress: Done **Result detail:** Major nonconformity

The confidentiality, integrity, and availability of data-at-rest are protected.

PR.DS-02 — - Not assessed

Progress: To do

The confidentiality, integrity, and availability of data-in-transit are protected.

PR.DS-10 — - Not assessed

Progress: To do

The confidentiality, integrity, and availability of data-in-use are protected.

PR.DS-11 — - Non compliant

Progress: Done **Result detail:** Major nonconformity

Backups of data are created, protected, maintained, and tested.

PR.PS-01 — - Not assessed

Progress: To do

Configuration management practices are established and applied.

PR.PS-02 — - Not assessed

Progress: To do

Software is maintained, replaced, and removed commensurate with risk.

PR.PS-03 — - Not assessed

Progress: To do

Hardware is maintained, replaced, and removed commensurate with risk.

PR.PS-04 — - Not assessed

Progress: To do

Log records are generated and made available for continuous monitoring.

PR.PS-05 — - Compliant

Progress: Done

Installation and execution of unauthorized software are prevented.

“Observation”: Assessment states Antivirus software is present

PR.PS-06 — - Not assessed

Progress: To do

Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle.

PR.IR-01 — - Not assessed

Progress: Done

Networks and environments are protected from unauthorized logical access and usage.

PR.IR-02 — - Compliant

Progress: Done **Result detail:** Good practice

The organization's technology assets are protected from environmental threats.

“Observation”: Asssessment states funtioning fire detection and prevention in place

PR.IR-03 — - Not assessed

Progress: To do

Mechanisms are implemented to achieve resilience requirements in normal and adverse situations.

PR.IR-04 — - Not assessed

Progress: To do

Adequate resource capacity to ensure availability is maintained.

DE.CM-01 — - Non compliant

Progress: Done **Result detail:** Major nonconformity

Networks and network services are monitored to find potentially adverse events.

DE.CM-02 — - Not assessed

Progress: To do

The physical environment is monitored to find potentially adverse events.

DE.CM-03 — - Not assessed

Progress: To do

Personnel activity and technology usage are monitored to find potentially adverse events.

DE.CM-06 — - Not assessed

Progress: To do

External service provider activities and services are monitored to find potentially adverse events.

DE.CM-09 — - Non compliant

Progress: Done **Result detail:** Opportunity for improvement

Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events.

DE.AE-02 — - Not assessed

Progress: To do

Potentially adverse events are analyzed to better understand associated activities.

DE.AE-03 — - Not assessed

Progress: To do

Information is correlated from multiple sources.

DE.AE-04 — - Not assessed

Progress: To do

The estimated impact and scope of adverse events are understood.

DE.AE-06 — - Not assessed

Progress: To do

Information on adverse events is provided to authorized staff and tools.

DE.AE-07 — - Not assessed

Progress: To do

Cyber threat intelligence and other contextual information are integrated into the analysis.

DE.AE-08 — - Not assessed

Progress: To do

Incidents are declared when adverse events meet the defined incident criteria.

RS.MA-01 — - Not assessed

Progress: To do

The incident response plan is executed in coordination with relevant third parties once an incident is declared.

RS.MA-02 — - Not assessed

Progress: To do

Incident reports are triaged and validated.

RS.MA-03 — - Not assessed

Progress: To do

Incidents are categorized and prioritized.

RS.MA-04 — - Not assessed

Progress: To do

Incidents are escalated or elevated as needed.

RS.MA-05 — - Not assessed

Progress: To do

The criteria for initiating incident recovery are applied.

RS.AN-03 — - Not assessed

Progress: To do

Analysis is performed to establish what has taken place during an incident and the root cause of the incident.

RS.AN-06 — - Not assessed

Progress: To do

Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved.

RS.AN-07 — - Not assessed

Progress: To do

Incident data and metadata are collected, and their integrity and provenance are preserved.

RS.AN-08 — - Not assessed

Progress: To do

An incident's magnitude is estimated and validated.

RS.CO-02 — - Not assessed

Progress: To do

Internal and external stakeholders are notified of incidents.

RS.CO-03 — - Not assessed

Progress: To do

Information is shared with designated internal and external stakeholders.

RS.MI-01 — - Not assessed

Progress: To do

Incidents are contained.

RS.MI-02 — - Not assessed

Progress: To do

Incidents are eradicated.

RC.RP-01 — - Not assessed

Progress: To do

The recovery portion of the incident response plan is executed once initiated from the incident response process.

RC.RP-02 — - Not assessed

Progress: To do

Recovery actions are selected, scoped, prioritized, and performed.

RC.RP-03 — - Not assessed

Progress: To do

The integrity of backups and other restoration assets is verified before using them for restoration.

RC.RP-04 — - Not assessed

Progress: To do

Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms.

RC.RP-05 — - Not assessed

Progress: To do

The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed.

RC.RP-06 — - Not assessed

Progress: To do

The end of incident recovery is declared based on criteria, and incident-related documentation is completed.

RC.CO-03 — -

Not assessed

Progress: To do

Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders.

RC.CO-04 — -

Not assessed

Progress: To do

Public updates on incident recovery are shared using approved methods and messaging.

Commitments

No commitments recorded.